

Where Do Enterprise Breaches Happen? Cloud, On-Premises, and the Evidence Gap

Sep 30, 2026 · @Sid

Abstract

Whether cloud or on-premises infrastructure is more secure is usually argued from vendor survey statistics rather than incident-level evidence. We test how far public breach records can settle the question. Applying a reproducible protocol to the VERIS Community Database (VCDB), we screened 10,047 incidents down to 994 confirmed enterprise breaches from 2019–2025. Four named mass-exploitation campaigns account for 797 of these (80%); the 2023 MOVEit Transfer compromise alone accounts for 716. Merging campaign victims yields 239 independent events under an automatic rule and 201 under a hand rule. Only 36 and 39 of them, respectively, record the affected environment in structured fields. Hand-coding all 162 unclassified hand-rule events recovered the environment for only 17 (10%; 95% CI 7–16%), so the gap is in the public record, not in the coding. Mandatory SEC Form 8-K disclosures from December 2023 to 2025 (65 events) name the environment about as often (34%) but rarely state a cause (17%), and none cites misconfiguration.

Three findings follow. First, counting victims instead of events reverses the cloud-versus-on-premises comparison, because a single unpatched product dominates victim counts. Second, among the 56 classifiable events, misconfiguration causes 53% of cloud breaches against 10% of on-premises breaches, a difference that holds under both campaign rules (permutation χ^2 , $p \leq 0.003$, Cramér's $V \approx 0.56$); because narratives reveal on-premises settings more readily than cloud ones, the two groups were classified differently and the comparison covers only breaches whose environment is knowable. Third, two 2025 campaigns against a shared SaaS CRM platform point to third-party integration as a growing cloud breach path. Re-weighting a Security Posture Index (SPI) by observed root-cause frequencies keeps cloud well above on-premises under every scheme (0.83–0.88 versus 0.61–0.68), but the hybrid advantage disappears when victims are counted. The evidence supports workload-specific, capability-aware placement and better-coded breach data; it does not support declaring any deployment model safest.

Keywords: cloud security, on-premises security, breach analysis, VERIS, shared responsibility model, mass exploitation, Security Posture Index, hybrid infrastructure

I. Introduction

Enterprises keep re-running the same infrastructure decision: move a workload to a hyperscale provider, or keep it in a data center they control. Security is usually the deciding argument, and it is usually argued badly. In a Cloud Security Alliance survey of 209 security, risk and IT professionals, 35% did not rate cloud security as at least equal to on-premises [1]. The counter-evidence most often quoted comes from vendor reports built on interviews or proprietary telemetry, which cannot be reproduced.

The intuition for on-premises is physical control. Data on servers the organization owns cannot be reached by a provider's staff, and no other tenant shares the hardware. The intuition for cloud is capability. Hyperscale providers employ security teams and patch pipelines that few enterprises can match. Both arguments are about *who protects* an asset, not *where* it sits, which is why the question resists a single answer.

This paper asks a narrower question first: **what can public, incident-level breach records actually tell us about cloud versus on-premises risk?** We make four contributions:

1. A reproducible sampling and coding protocol that maps VERIS fields to infrastructure model and root cause, with a pinned dataset version and scripts available for re-use (Section III).
2. Evidence that mass-exploitation campaigns dominate raw breach counts, and that victim-level counting badly distorts deployment-model comparisons (Section IV).
3. A measurement, in VCDB and in mandatory SEC Form 8-K disclosures, of how rarely public records identify the affected environment and cause, which bounds what any breach-count study can claim (Section IV).
4. A Security Posture Index with weight-sensitivity analysis and weights derived from observed root causes, and a Hybrid Security Optimization Model (HSOM) recast as a decision framework to be tested, not a proven result (Appendices A and B).

Section II reviews related work, Section III describes the data and methods, Section IV reports results, Section V discusses implications, regulation and limitations, and Section VI concludes. Appendix A gives the Security Posture Index and Appendix B the placement model.

II. Background and Related Work

Shared responsibility. Under the shared responsibility model, the provider secures the infrastructure of the cloud (facilities, hardware, hypervisor, network backbone) and the customer secures what runs *in* it (identities, configuration, data). The provider's share

grows from IaaS to PaaS to SaaS [2]. On-premises, the organization owns every layer. Writing the total security surface as the disjoint union of provider and customer parts:

$$\Sigma = \Sigma_{\text{provider}} \cup \Sigma_{\text{customer}}, \quad \Sigma_{\text{provider}} \cap \Sigma_{\text{customer}} = \emptyset \quad (1)$$

On-premises, the provider term is empty. In cloud deployments it is non-empty and largest under SaaS. The model predicts that cloud breaches should cluster in the customer's share, especially configuration and identity.

Breach cost and frequency evidence. The most cited figures come from the IBM/Ponemon *Cost of a Data Breach* series, which interviews several hundred breached organizations each year. Its 2026 edition reports a global mean cost of USD 4.99 million, a record high and 12% above the prior year [3]. The series also reports cost by data-storage location. In the 2024 edition, about 40% of breaches involved data spread across multiple environments, and breaches confined to public cloud were the most expensive, at USD 5.17 million [4]. That ordering cuts against the claim that on-premises breaches cost more, and the large multi-environment share argues against assuming hybrid estates are safer.

The Verizon *Data Breach Investigations Report* (DBIR) analyzes tens of thousands of incidents. Its 2026 edition, covering incidents from November 2024 to October 2025, finds vulnerability exploitation is now the leading initial access vector (31% of breaches), ahead of stolen credentials, and that ransomware is present in 48% of breaches [5]. The same report finds third-party involvement in 48% of breaches, up from 30%, and that only 26% of critical vulnerabilities in the CISA Known Exploited Vulnerabilities catalog [6] were fully remediated in 2025 [5].

Peer-reviewed work urges caution with headline cost figures. Romanosky found typical incident costs far below survey-based averages across about 12,000 incidents [7].

Edwards, Hofmeyr and Forrest showed breach sizes follow heavy-tailed distributions, so means are unstable and medians or non-parametric tests are needed [8].

Measurement with incident datasets. VCDB has supported earlier measurement work. Liu et al. [9] paired VCDB and other incident reports with externally observed signs of network mismanagement to forecast which organizations would be breached, and Sarabi et al. [10] used VCDB with business profiles to predict the type of breach an organization would suffer. Neither study separates cloud from on-premises incidents, and both treat each record as an independent event. Woods and Böhme [11] systematize how cyber risk

is quantified and the incident and loss data on which those estimates rest. Our coverage and campaign analysis adds a concrete measure of how far one widely used dataset can support environment-level claims.

Misconfiguration, mass exploitation and credentials. Continella et al. [12] scanned cloud object storage at scale and found many buckets readable or writable by anyone, the customer-side failure that dominates our classifiable cloud breaches. Durumeric et al. [13] showed how one vulnerability, Heartbleed, exposed a large share of internet servers and how slowly they were patched, the same dynamic behind the MOVEit and Oracle E-Business Suite campaigns in our data. Thomas et al. [14] traced how credentials stolen through breaches, phishing and malware are reused in account takeover, which underlies the credential-driven SaaS campaigns of 2025.

Gap. No study we found compares cloud and on-premises breaches using an open, incident-level dataset with a published coding protocol. Vendor reports cannot be reproduced, and they do not say how campaigns or multi-environment incidents are counted. This paper addresses that gap.

III. Data and Methods

Source. We used the validated JSON records of the VERIS Community Database (VCDB) [15], an open dataset of publicly reported incidents coded in the Vocabulary for Event Recording and Incident Sharing (VERIS) [16]. VCDB is the community counterpart to the DBIR corpus. Records were taken at repository commit f6f98c00 on 30 September 2026. The extraction and analysis scripts, coding sheets, campaign list and all outputs are available at <https://github.com/schennuri/breach-evidence-gap>; a single script reproduces every result in this paper.

Inclusion. An incident was included if all of the following held:

Table I — Inclusion criteria

Criterion	VERIS field	Rule
Study period	<code>timeline.incident.year</code>	2019–2025
Confirmed breach	<code>attribute.confidentiality.data_disclosure</code>	Yes
Enterprise scale	<code>victim.employee_count</code>	Large, or 1,001 employees and above

Criterion	VERIS field	Rule
Not availability-only	<code>action.hacking.variety</code>	Not DoS as the only action
Not endpoint-only	<code>asset.assets.variety</code>	At least one asset that is not a user device or media

Campaign collapsing. Mass-exploitation campaigns produce one VCDB record per victim. Counting each victim as an independent breach would weight a single root cause by the number of organizations that ran the vulnerable product. We therefore collapsed records sharing a VERIS `campaign_id`, or sharing an identical incident summary across five or more victims, into one event. The number of victims is retained as `campaign_size` so that victim-weighted results can be reported alongside.

We call this the *automatic rule* (rule A). Because it depends on identical wording, it merged MOVEit victims but left most victims of the 2025 campaigns as separate events. We therefore also apply a *hand rule* (rule B). Reading every 2025 narrative and reference, we identified four named campaigns and merged their victims: MOVEit Transfer (2023, 716 victims), Oracle E-Business Suite zero-day exploitation (2025, 13), Salesloft Drift OAuth-token theft (2025, 24) and the Salesforce CRM social-engineering wave attributed to ShinyHunters (2025, 44). Five of the 44 were assigned from press attribution because their VCDB narrative names only a third-party customer-service platform. Each campaign also receives a hand code: MOVEit and Oracle EBS as on-premises exploited vulnerabilities, since both products are customer-operated; Drift as cloud third-party compromise; and the Salesforce wave as cloud credential attack. Campaign membership is listed in the released `campaigns.csv`. All results are reported under both rules.

Infrastructure classification. The primary field is `asset.cloud`, which takes the values On-Premise Asset(s) and External Cloud Asset(s).

Table II — Infrastructure classification rules

Coded model	Rule
Cloud	Only External Cloud Asset(s), or a Hypervisor or Inter-tenant attack vector
On-premises	Only On-Premise Asset(s)

Coded model	Rule
Hybrid	Both values present, or an attack path that crossed environments on manual review
Manual review	Unknown, NA or absent, with a narrative or source reference available

Records coded under older schemas fall back to `asset.hosting`: Internal maps to on-premises, External shared to cloud, and External dedicated to manual review, because it covers both colocation and private cloud.

Under rule A, 203 of 239 independent events reached manual review; under rule B, 162 of 201.

Hand-coding of unclassified events. We hand-coded all 162 rule-B events needing review. We first coded a sample of 60, stratified by incident year in proportion to the pool (2019: 26, 2020: 25, 2021: 6, 2024: 2, 2025: 1; random seed 2026), to estimate how often narratives reveal the environment, then coded the remaining 102 under the same rules. For each event, a coder read the full VCDB narrative and its source references and assigned an environment only where the text stated or directly implied where the compromised data or system resided (for example "cloud database", "storage buckets", "self-hosted environment", or servers on the organization's own network). Otherwise the event was coded undetermined. Root cause was recoded under the same precedence rules. All 162 events were coded by a single coder, using a language model to help read the narratives; no independent second coding was performed. Because single-coder judgments can be biased, we compare the hand codes with the independent automated codes and record the text basis for every decision in the coding sheet, so that others can re-code them.

Root cause. Each event received one primary root cause, using a fixed precedence that favors the earliest enabling condition: physical access; third party (`actor.partner` or a Partner vector); insider misuse; exploited vulnerability; misconfiguration (`action.error Misconfiguration` or `action.hacking Exploit misconfig`); credential attack (stolen credentials, brute force, pass-the-hash, or social engineering that disclosed credentials); other. A second ordering, with technical causes first, is computed for robustness.

Impact variables. Detection and containment times come from `timeline.discovery` and `timeline.containment`, converted to days where a value is recorded and kept as ordinal units otherwise. Losses come from `impact.overall_amount` and itemized `impact.loss`. Missing values are left missing and not imputed.

SEC Form 8-K disclosures. Since December 18, 2023, US public companies must report material cybersecurity incidents under Item 1.05 of Form 8-K within four business days [22]; after SEC staff guidance in May 2024, many report incidents not yet judged material under Item 8.01 instead [23]. We queried EDGAR full-text search for 8-K filings dated December 18, 2023 to December 31, 2025 that report Item 1.05, or that report Item 8.01 and contain the phrase "cybersecurity incident", and extracted the item text of each, or the attached press release when the item only referred to it. The query returned 206 filings from 139 companies. Reading each filing, we kept the first disclosure of each incident (68 incidents), linked 26 later filings to their incident as updates, and excluded 112 that were not incident reports, almost all dividend, offering or merger announcements whose risk factors mention cybersecurity incidents. Each incident was hand-coded from the filing text alone with the VCDB environment and root-cause codebook, and any dollar figure disclosed was recorded. Four automotive dealers reported the June 2024 outage at CDK Global, their dealer-management provider; as under rule B, we merge them into one event, leaving 65 events. The collector, screening log and codes are in the repository.

Analysis. Root-cause distributions for cloud and on-premises events are compared with a χ^2 statistic whose p-value comes from 20,000 random permutations of the environment labels, because many expected cell counts fall below 5; effect size is Cramér's V. The comparison combines events classified from structured fields with those classified by hand, and is run under both campaign rules. Agreement between automated and hand codes is measured with Cohen's κ [17], and the share of determinable events is given with a Wilson 95% interval [18]. Two planned analyses could not be run: losses are recorded for only 2 of 201 events, and no event records a regulatory fine, so neither a cost comparison nor a regression on fines is estimable from VCDB. Detection and containment times are reported descriptively. SEC and VCDB events are compared with Fisher's exact test on four shares: events with a determinable environment, cloud among those, events with a stated cause, and misconfiguration.

IV. Results

A. Screening. Of 1,643 VCDB records with an incident year of 2019–2025, 994 met every inclusion criterion (Fig. 1). Under the automatic campaign rule these collapse to 239 independent events. Only 36 of those (15%) recorded the affected environment in structured fields: 31 cloud, 5 on-premises and none hybrid. The other 203 need manual review of the source narrative.

Only 36 of 994 eligible breaches record where the breach happened

VCDB screening of 2019–2025 incidents, from 10,047 validated records; grey text = drop from previous step

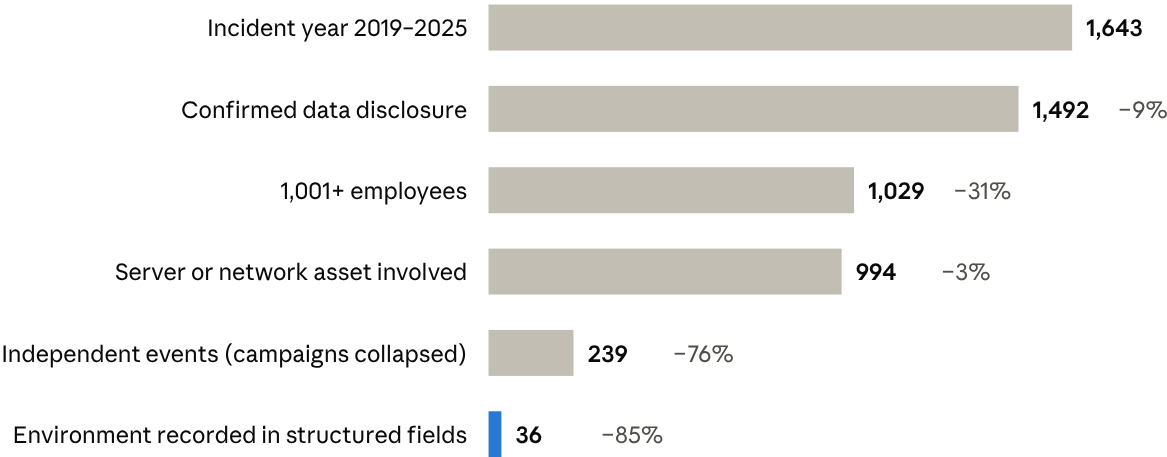


Fig. 1 — VCDB commit f6f98c00, extracted 30 Sep 2026; automatic campaign rule

Coverage is uneven by year. Usable records cluster in 2019–2020 and 2025, with very few for 2022 and 2024, which most likely reflects VCDB coding backlog (Fig. 2).

Usable VCDB records nearly vanish for 2022 and 2024

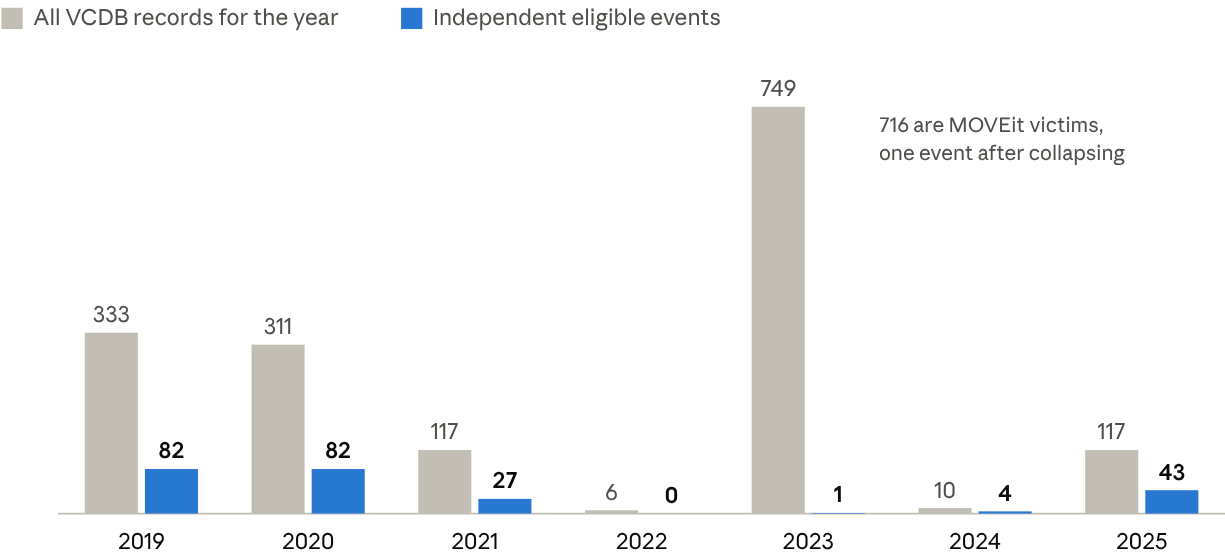


Fig. 2 — VCDB commit f6f98c00, records by incident year

B. Campaign concentration. A single campaign, the 2023 exploitation of the MOVEit Transfer file-transfer product, accounts for 716 of the 994 eligible records (72%). Twelve smaller campaigns of 2–26 victims account for another 52. How campaigns are counted

reverses the comparison between deployment models (Fig. 3).

Counting victims instead of events flips cloud versus on-premises

Share of classifiable breaches: 36 events vs 751 victim records

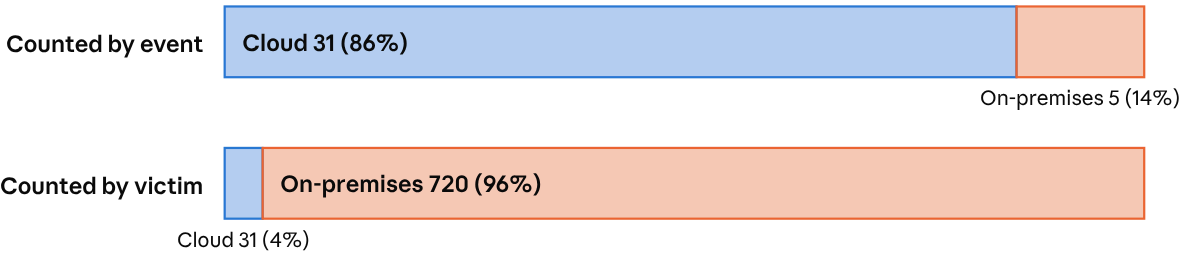


Fig. 3 — Classifiable events, automatic rule; 203 unclassified events (243 victim records) excluded

Counted by victim, on-premises breaches outnumber cloud breaches 23 to 1, and 99% of them trace to one unpatched product. Counted by event, cloud outnumbers on-premises 6 to 1. Neither figure supports a claim about which model is safer; the choice of unit drives the answer. A further cluster of August 2025 records describes compromise of customer data through the Salesloft Drift integration with a shared CRM platform (Workday, Toast, Esker, AppFolio and others). Because each victim's summary differs, the automatic rule counts these as separate events; the hand rule merges them.

Under the hand rule, four campaigns account for 797 of the 994 victim records (80%), and the 994 records collapse to 201 independent events:

Table III — Named campaigns merged under the hand rule

Campaign	Year	Victim records	Environment	Root cause
MOVEit Transfer zero-day	2023	716	On-premises	Exploited vulnerability
Salesforce CRM social-engineering wave	2025	44	Cloud (SaaS)	Credential attack
Salesloft Drift OAuth-token theft	2025	24	Cloud (SaaS)	Third party
Oracle E-Business Suite zero-day	2025	13	On-premises	Exploited vulnerability

The two 2025 cloud campaigns reached 68 organizations through one shared CRM platform, the first by deceiving staff and the second through a compromised integration. The two on-premises campaigns reached 729 organizations through two customer-operated products. In each environment, a handful of shared components produced most of the victims.

C. Hand coding. In the stratified sample of 60, the narrative or references identified the environment for 9 (15%; Wilson 95% CI 8–26%). Across all 162 unclassified events the rate was lower: 17 (10%; 7–16%), of which 3 were cloud and 14 on-premises. The other 145 described the data lost but not where it was held, so even full manual review leaves about nine in ten public breach records without an environment. On-premises incidents were easier to place, mostly because ransomware narratives mention the victim’s network or physical devices, while cloud narratives rarely name the hosting model. Hand coding therefore adds on-premises events faster than cloud ones. Automated and hand root-cause codes agreed on 136 of 162 events (84%; Cohen’s $\kappa = 0.76$). Disagreements mostly concerned email-account compromise with no stated method, application flaws, and third-party involvement.

D. Root causes. Under the automatic rule, credential attacks are the most common identified root cause, 62 of 239 events, followed by misconfiguration (Fig. 4). Most of those credential events are separate victims of the two 2025 campaigns against the shared CRM platform; under the hand rule they merge, credential attacks fall to 26 of 201, and misconfiguration (45) becomes the leading identified cause.

Credential attacks are the most common identified root cause

Primary root cause of 239 independent breach events, VCDB 2019–2025, campaigns counted once

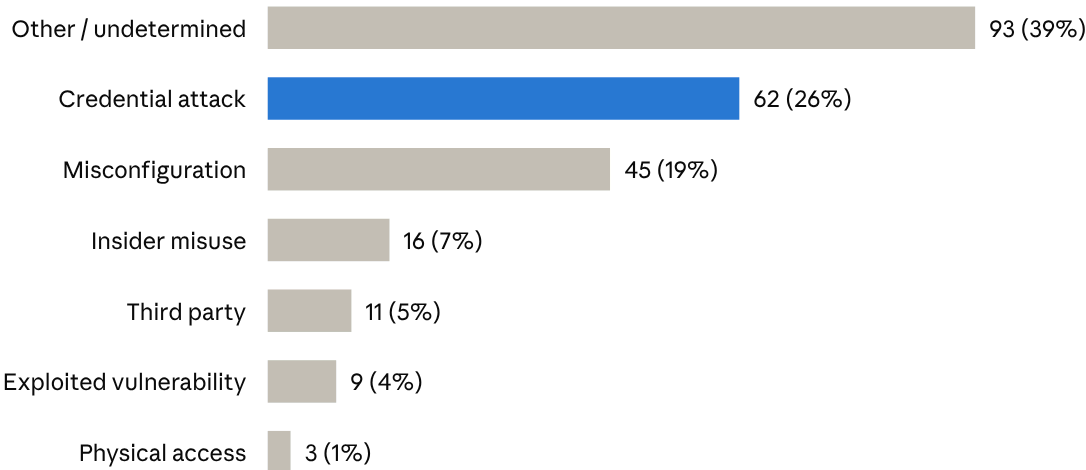


Fig. 4 — VCDB commit f6f98c00, automated precedence coding, automatic rule

Among the 31 classifiable cloud events, misconfiguration is the leading cause (17, or 55%). The five on-premises events each have a different cause, so no on-premises distribution can be estimated; Section IV-E pools them with the hand-coded events to test the difference. VERIS coded the Salesloft Drift victims as stolen-credential use rather than partner compromise, so automated coding undercounts third-party involvement; the hand rule recodes them (Table III).

E. Environment and root cause. Combining events classified from structured fields with those classified by hand gives 56 events under the hand rule (Fig. 5).

Misconfiguration drives cloud breaches; on-premises causes are spread out

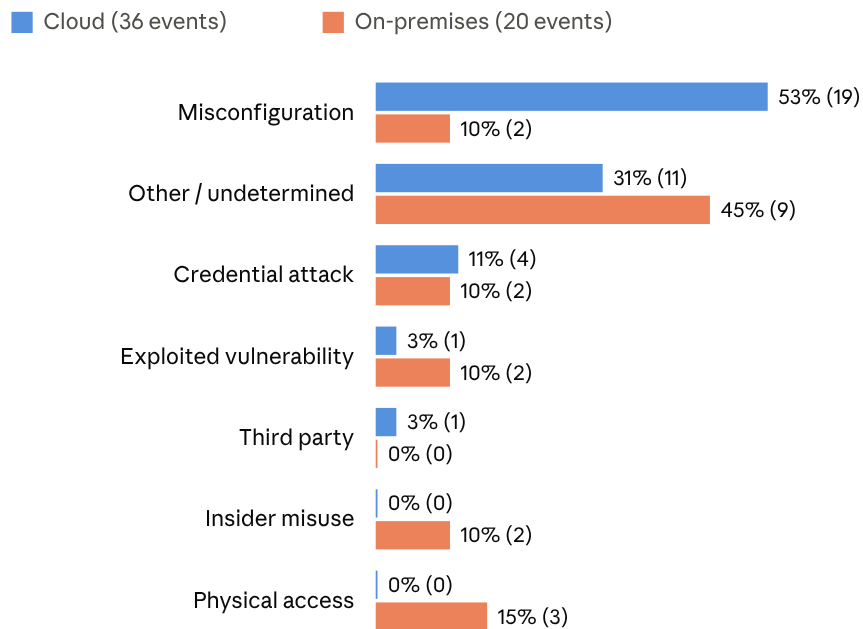


Fig. 5 — Hand campaign rule; structured-field and hand-coded events combined (n = 56)

Misconfiguration causes 53% of classifiable cloud breaches and 10% of on-premises breaches. The on-premises distribution is spread across six causes; the largest, other or undetermined, covers 9 of 20, mostly ransomware with no stated entry point.

Table IV — Test of root cause by environment under both campaign rules

Campaign rule	Cloud events	On-prem events	χ^2	Permutation p	Cramér's V
A, automatic	34	19	16.22	0.003	0.55
B, hand	36	20	17.85	0.002	0.57

The effect is large and significant under both rules, and now rests on 19–20 on-premises events. We read it as consistent with the shared-responsibility prediction that cloud breaches concentrate in customer configuration, not as a settled difference. The misconfiguration share is 53% for cloud (95% CI 37–68%) and 10% for on-premises (3–30%); simulating at these shares and sample sizes gives the test about 91% power at $\alpha = 0.05$. Two cautions remain. The cloud events come almost entirely from structured fields and the added on-premises events almost entirely from hand coding, so the two groups were classified in different ways. And the 56 classified events are just over a quarter of all 201, so the comparison describes breaches whose environment is knowable, not all breaches.

F. Alternative root-cause ordering. Re-running the automated coding with technical causes ahead of actor-based causes changes the primary code of 7 events under either rule.

Table V — Root-cause counts under primary and alternative precedence

Root cause	Rule A, primary	Rule A, alternative	Rule B, primary	Rule B, alternative
Credential attack	62	64	26	28
Misconfiguration	45	48	45	48
Insider misuse	16	17	16	17
Third party	11	4	12	5
Exploited vulnerability	9	10	6	7
Physical access	3	3	3	3
Other / undetermined	93	93	93	93

Only the third-party count is sensitive: most events coded third party under the primary order also record a technical cause, and move to it under the alternative. The ranking of the main causes is unchanged.

G. Impact data. Of the 201 rule-B events, 32 record a detection time, 21 a containment time and 2 a monetary loss; none records a regulatory fine. A breach-cost or fine comparison by deployment model therefore cannot be built from VCDB, and cost figures

in this paper come from the external reports in Section II.

H. SEC Form 8-K disclosures. The 206 filings yield 68 incidents at 67 companies (ADT disclosed two), 40 of them reported under Item 1.05 at some point; merging the four CDK Global dealers leaves 65 events. Filings name the affected environment about as often as VCDB records do, but the environment they name is different, and the cause is usually missing (Table VI).

Table VI — SEC Form 8-K events compared with VCDB events under the hand rule

Measure	SEC 8-K (65 events)	VCDB (201 events)	Fisher p
Environment stated	22 (34%)	56 (28%)	0.35
Cloud, share of those	4 of 22 (18%)	36 of 56 (64%)	< 0.001
Root cause stated	11 (17%)	108 (54%)	< 0.001
Misconfiguration	0 (0%)	45 (22%)	< 0.001

Of the 22 events with a stated environment, 18 are on-premises: ransomware or intrusions that the filing places on the company's "network", "servers" or "internal systems". The four cloud events are HPE's cloud-based email, AT&T's workspace on a third-party cloud platform, the Dropbox Sign production environment and CDK's hosted dealer-management platform. Only 11 events state a cause, and none is a misconfiguration: 7 came through a vendor or partner (among them CDK, Evolve Bank and a fourth-party vendor of the Federal Home Loan Bank of New York), 3 were insiders (support contractors paid by the attacker at Coinbase, a former Coupang employee and a former Meta Materials executive), and 1 exploited the Oracle E-Business Suite zero-day also seen in VCDB. Under the alternative ordering, two vendor cases become stolen credentials and one a vulnerability. VCDB causes come partly from curators' structured codes, which draw on press coverage, while SEC causes come from the filing alone, so part of the gap in stated causes reflects the source of the code.

Seven incidents disclose a dollar figure, from about \$180,000 of remediation at Data I/O to about \$1.2 billion of customer vouchers at Coupang; loanDepot (\$12–17 million net of insurance), Key Tronic (\$2.3 million, plus about \$15 million of revenue it could not fulfill) and Coinbase (\$180–400 million, preliminary) lie between, and two are misdirected payments. Six of the seven have no stated environment, so 8-K costs cannot support a comparison by deployment model either. The filings do cover the period VCDB covers thinly: 42 of the 68 incidents were disclosed in 2024 (Fig. 2).

V. Discussion

Why the perception gap persists. The belief that on-premises is safer survives partly because neither side's evidence is decisive. Our data shows why. Public records rarely say where a breach happened, and the incidents that dominate raw counts are a few mass campaigns. A practitioner who remembers MOVEit sees on-premises risk; one who remembers exposed cloud storage sees cloud risk. Both are generalizing from campaigns, not from independent events. The model in Appendix A suggests the more useful question is capability: an organization whose own controls are weak gains most from a provider's baseline.

Mass exploitation reframes on-premises risk. On-premises exposure in this sample is concentrated, not diffuse. One vulnerable file-transfer product produced 716 victim records. This supports the patch-management argument for cloud, but in a specific form: the risk is internet-facing on-premises appliances and managed file-transfer software exposed to zero-day campaigns, consistent with the DBIR finding that exploitation now leads initial access and that most critical KEV entries go unremediated within the year [5]. Many MOVEit victims were also compromised through a service provider, so the same event is a third-party story as much as an on-premises one.

Cloud risk is shifting toward integrations. Among classifiable cloud breaches, misconfiguration dominates, as the shared-responsibility model predicts. The 2025 cluster of disclosures linked to a shared SaaS platform points to a different path: attackers reaching many tenants through a common integration, connected app or support process, often after social engineering. This matches the rise in third-party involvement reported by the DBIR, and it is a form of the concentration risk HSOM's R term is meant to price.

Mandatory disclosure moves the gap rather than closing it. Form 8-K filings describe operational impact, because materiality turns on it, and rarely say how the attacker got in. Exposed databases, the misconfiguration breaches that dominate VCDB's cloud records, are usually found by researchers and seldom judged material, so they do not appear in 8-K filings at all. The two sources therefore see different breaches: VCDB leans toward data exposures and US healthcare notifications, 8-K filings toward disruptive ransomware at listed companies. Neither samples all breaches, so pooled counts should be reported by source. If 8-K filings stated the affected environment and the initial access vector, as VERIS records do, a few years of filings could answer the question this paper cannot.

Hybrid is not automatically safer. In IBM's 2024 data, about 40% of breaches involved data spread across multiple environments, the most common storage pattern among breached organizations. That is compatible with HSOM only if *designed* hybrid placement differs from *accidental* data sprawl across environments. We think it does, but the distinction is untested. Until breach records identify cross-environment attack paths, claims that hybrid is empirically safest are not supported.

Regulation. NIS2 [19] and US Executive Order 14028 [20] accept cloud deployments as compliant postures. DORA [21] adds concentration-risk and exit-strategy requirements for EU financial entities, which pushes regulated firms toward planned multi-environment architectures. Regulation is therefore moving toward the workload-specific placement HSOM formalizes, while also raising the stakes of getting cross-environment identity right.

Implications for workload placement. Appendix A turns the shared-responsibility argument into a Security Posture Index. With weights set from the root causes observed here, cloud scores well above on-premises under every weighting tested, while any advantage for hybrid estates rests on assumptions the data cannot yet check. Appendix B states the resulting placement model as three testable propositions. Both are aids for structuring a decision, not findings of this study.

Limitations.

- *Selection.* VCDB holds only publicly reported incidents and over-represents sectors with mandatory disclosure, notably US healthcare.
- *Coverage.* Usable 2022 and 2024 records are sparse, likely reflecting coding backlog rather than fewer breaches.
- *Classification.* 81% of independent events (hand rule) lack a structured environment code, and hand review recovers it for about 10% of those, more often for on-premises than for cloud incidents; results for the classified subset may not generalize. Hand coding of VCDB and SEC records was done by a single coder.
- *SEC filings.* Item 8.01 filings were found only if they use the phrase "cybersecurity incident", so incidents described in other words are missed. Codes rest on the filing text alone, so an environment named only in press coverage is coded undetermined, and one filing (Globe Life) yielded no readable incident text.
- *Impact data.* Losses are almost never recorded and timing is recorded for very few events, so cost comparisons rely on external reports.
- *Model.* SPI scores and weights were assigned by the author without a formal panel, and the functional forms favor cloud at low capability by design.

- *Causality*. Organizations that keep workloads on-premises differ in industry, age and regulation; all findings are associations.

VI. Conclusion and Future Work

Public incident-level breach data cannot currently tell us whether cloud or on-premises infrastructure is more secure. Of 994 confirmed enterprise breaches in VCDB for 2019–2025, 797 were victims of four campaigns. Of the 201 independent events that remain under hand merging, 39 recorded the affected environment, and hand-coding the rest recovered it for only 10% of them. Mandatory SEC disclosures do not close the gap: of 65 events reported on Form 8-K, 34% name the environment and 17% the cause. Any claim that one deployment model accounts for a given share of breaches should state how campaigns and unclassified incidents were handled.

Within those limits, the evidence is consistent with three conclusions. On-premises risk is concentrated in mass exploitation of exposed appliances and file-transfer software. About half of classifiable cloud breaches are customer misconfiguration. Third-party and shared-platform paths are growing for both. The corrected SPI ranks cloud well above on-premises in 99.9% of sampled weightings and under weights derived from observed root causes, while the hybrid advantage is small, rests on insider-threat resilience, and disappears when victims rather than events set the weights. The defensible policy is the one HSOM formalizes: place each workload by capability, regulation and concentration risk, and stop treating the deployment model as the security control.

Future work will (1) add independent second coding of the 162 hand-coded events and search their source articles for cross-environment attack paths; (2) add a third-party and supply-chain dimension to the SPI; (3) extend the SEC Form 8-K coding [22] beyond 2025 and link each incident to later 10-K reports and state breach-notification letters, which often name the access vector the 8-K omits; and (4) test HSOM placements against outcomes once hybrid incidents can be identified.

References

- [1] Cloud Security Alliance, "The cloud balancing act for IT: Between promise and peril," CSA, Jan. 2016.
- [2] P. Mell and T. Grance, "The NIST definition of cloud computing," NIST, Gaithersburg, MD, USA, Special Publication 800-145, 2011.

- [3] IBM Security and Ponemon Institute, "Cost of a data breach report 2026," IBM, Armonk, NY, USA, 2026. [Online]. Available: <https://www.ibm.com/reports/data-breach>
- [4] IBM Security and Ponemon Institute, "Cost of a data breach report 2024," IBM, Armonk, NY, USA, 2024.
- [5] Verizon Business, "2026 data breach investigations report," Verizon, 2026. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>
- [6] Cybersecurity and Infrastructure Security Agency, "Known exploited vulnerabilities catalog." [Online]. Available: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [7] S. Romanosky, "Examining the costs and causes of cyber incidents," *J. Cybersecurity*, vol. 2, no. 2, pp. 121–135, 2016.
- [8] B. Edwards, S. Hofmeyr, and S. Forrest, "Hype and heavy tails: A closer look at data breaches," *J. Cybersecurity*, vol. 2, no. 1, pp. 3–14, 2016.
- [9] Y. Liu, A. Sarabi, J. Zhang, P. Naghizadeh, M. Karir, M. Bailey, and M. Liu, "Cloudy with a chance of breach: Forecasting cyber security incidents," in *Proc. 24th USENIX Security Symp.*, 2015, pp. 1009–1024.
- [10] A. Sarabi, P. Naghizadeh, Y. Liu, and M. Liu, "Risky business: Fine-grained data breach prediction using business profiles," *J. Cybersecurity*, vol. 2, no. 1, pp. 15–28, 2016.
- [11] D. W. Woods and R. Böhme, "SoK: Quantifying cyber risk," in *Proc. IEEE Symp. Security and Privacy*, 2021.
- [12] A. Continella, M. Polino, M. Pogliani, and S. Zanero, "There's a hole in that bucket! A large-scale analysis of misconfigured S3 buckets," in *Proc. Annu. Computer Security Applications Conf. (ACSAC)*, 2018.
- [13] Z. Durumeric et al., "The matter of Heartbleed," in *Proc. ACM Internet Measurement Conf. (IMC)*, 2014.
- [14] K. Thomas et al., "Data breaches, phishing, or malware? Understanding the risks of stolen credentials," in *Proc. ACM Conf. Computer and Communications Security (CCS)*, 2017.
- [15] Verizon RISK Team, "VERIS Community Database (VCDB)," commit f6f98c00, accessed Sep. 30, 2026. [Online]. Available: <https://github.com/vz-risk/VCDB>
- [16] Verizon RISK Team, "Vocabulary for Event Recording and Incident Sharing (VERIS)," schema v1.3.x. [Online]. Available: <https://github.com/vz-risk/veris>

- [17] J. Cohen, "A coefficient of agreement for nominal scales," *Educ. Psychol. Meas.*, vol. 20, no. 1, pp. 37–46, 1960.
- [18] E. B. Wilson, "Probable inference, the law of succession, and statistical inference," *J. Amer. Statist. Assoc.*, vol. 22, no. 158, pp. 209–212, 1927.
- [19] *Directive (EU) 2022/2555 (NIS2 Directive)*, Off. J. Eur. Union, L 333, Dec. 2022.
- [20] *Executive Order 14028: Improving the Nation's Cybersecurity*, 86 Fed. Reg. 26633, May 2021.
- [21] *Regulation (EU) 2022/2554 on Digital Operational Resilience for the Financial Sector (DORA)*, Off. J. Eur. Union, L 333, Dec. 2022.
- [22] U.S. Securities and Exchange Commission, "Cybersecurity risk management, strategy, governance, and incident disclosure," Release No. 33-11216, Jul. 2023.
- [23] E. Gerding, "Disclosure of cybersecurity incidents determined to be material and other cybersecurity incidents," Statement, U.S. Securities and Exchange Commission, Division of Corporation Finance, May 21, 2024.

Appendix A. Security Posture Index

Threat exposure. For deployment model $M \in \{\text{cloud, on-prem, hybrid}\}$ and n threat dimensions, threat exposure is:

$$E(M) = \sum_{i=1}^n w_i V_i(M) (1 - C_i(M)), \quad \sum_{i=1}^n w_i = 1 \quad (2)$$

Here V is the probability that dimension i is exploited, C is countermeasure effectiveness and w is impact weight. Organizational security capability $\kappa \in [0, 1]$ changes C differently in each model:

$$C_i^{\text{on}}(\kappa) = \bar{C}_i^{\text{on}} \kappa, \quad C_i^{\text{cl}}(\kappa) = \bar{C}_i^{\text{cl}} + (1 - \bar{C}_i^{\text{cl}}) \kappa \delta_i \quad (3)$$

On-premises, every control is the organization's own, so effectiveness scales with κ from zero. In cloud, the provider's baseline holds at any κ , and the organization adds to it through a leverage factor δ . δ is near 0 for physical security, which an enterprise cannot improve on, and high for insider threat, where the organization knows its own workforce. **This asymmetry encodes the shared responsibility model, and it favors cloud by construction at low κ .** We state it as an assumption, not a finding.

On-premises has lower exposure than cloud on dimension i when:

$$V_i^{\text{on}}(1 - \bar{C}_i^{\text{on}}\kappa) < V_i^{\text{cl}}(1 - \bar{C}_i^{\text{cl}} - (1 - \bar{C}_i^{\text{cl}})\kappa\delta_i) \quad (4)$$

The κ at which this flips is specific to each dimension and depends entirely on the assigned parameters. We therefore do not report a single universal threshold.

Security Posture Index. SPI normalizes exposure to $[0, 1]$, with higher meaning stronger posture. The composite SPI for a model is the weighted sum of its dimension scores. Table VII gives the dimension scores and weights. They were assigned by the author from the evidence summarized in Section II and professional judgment in security governance; no formal elicitation panel was used, which is why this appendix tests how far the conclusions depend on them. The column *Hybrid (bounded)* applies a no-synergy constraint: a hybrid estate places each workload in the better of the two environments, so on any dimension it cannot exceed the stronger of cloud or on-premises.

Table VII — Seven-dimension SPI scores (author-assigned) and corrected composites

Dimension	Weight	Cloud	On-prem	Hybrid (as assigned)	Hybrid (bounded)
Data confidentiality	0.18	0.86	0.71	0.89	0.86
Access control / IAM	0.17	0.83	0.67	0.86	0.83
Patch management	0.16	0.91	0.58	0.84	0.91
Physical security	0.14	0.94	0.72	0.91	0.94
Incident response	0.13	0.79	0.63	0.82	0.79
Compliance auditability	0.12	0.88	0.65	0.90	0.88
Insider threat resilience	0.10	0.66	0.74	0.79	0.74
Composite SPI	1.00	0.847	0.669	0.862	0.855

Composites are computed from the row values. Under the assigned scores, hybrid leads cloud by 0.015. Under the bounded scores, the lead is 0.008, and all of it comes from insider-threat resilience, the only dimension where on-premises outscores cloud. Assigned hybrid scores above both components imply synergy between environments, which would need its own evidence.

Cloud leads on six of seven dimensions; the widest gap is patch management

SPI score difference, cloud minus on-premises (Table VII); right of zero favours cloud

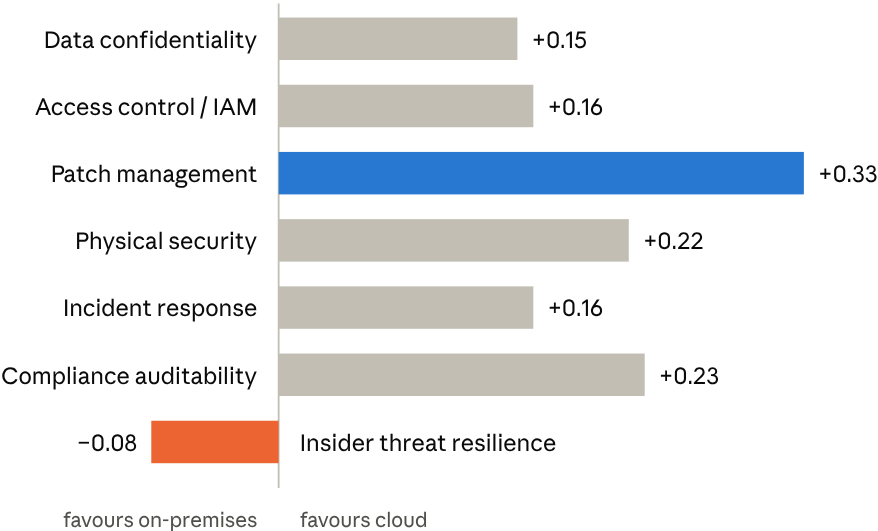


Fig. 6 — Computed from Table VII scores

Insider-threat resilience is the only dimension that favours on-premises, which is why it alone carries the bounded hybrid’s lead (Fig. 6).

Role of the SPI and data-informed weights. The dimension scores remain author judgments, so the SPI is a structured way to state assumptions, not a measurement. Its weights, however, can be tied to the breach data. We map each observed root cause to one dimension: credential attacks to access control, misconfiguration to data confidentiality, exploited vulnerabilities to patch management, physical access to physical security, and insider misuse to insider-threat resilience. Incident response and compliance auditability describe how breaches are handled rather than how they start, so they keep their assigned weights (0.13 and 0.12). The remaining 0.75 is split in proportion to root-cause frequencies under the hand campaign rule, including the hand-coded events (Section IV).

Table VIII — Composite SPI under assigned and data-informed weights

Weighting	Cloud	On-prem	Hybrid (as assigned)	Hybrid (bounded)
Assigned	0.847	0.669	0.862	0.855
Data-informed, events (n = 92)	0.827	0.682	0.861	0.837

Weighting	Cloud	On-prem	Hybrid (as assigned)	Hybrid (bounded)
Data-informed, victims (n = 862)	0.881	0.608	0.847	0.882

Event weights are dominated by misconfiguration (48% of mapped events) and credential attacks (24%); victim weights by exploited vulnerabilities (85%), because of MOVEit and Oracle EBS. Cloud outscores on-premises under every scheme. The hybrid lead holds under event weights but vanishes under victim weights, where cloud matches the bounded hybrid and beats the as-assigned one. Third-party compromise, 9 events and 32 victim records in our data, maps to no SPI dimension at all. That is a gap in the framework, and we flag it as the first extension for future work.

Weight sensitivity. We tested whether the Table VII ranking depends on the assigned weights, using the assigned hybrid scores.

Table IX — Sensitivity of the composite SPI ranking to weights

Test	Result
Each weight scaled 0×, 0.5×, 1.5×, 2× (28 cases)	Ranking hybrid > cloud > on-premises unchanged; hybrid lead 0.002–0.031
Break-even for cloud to overtake hybrid	Patch-management weight ≥ 0.30 (from 0.16), or physical-security weight ≥ 0.42 (from 0.14)
Dirichlet sampling around baseline weights, 100,000 draws	Hybrid ranks first in 99.7%, 89.5% and 75.8% of draws at low, moderate and high uncertainty
Uniform sampling of all weights, 100,000 draws	Hybrid first in 84.7%; cloud above on-premises in 99.9%
Equal weights	Hybrid 0.859, cloud 0.839, on-premises 0.671

On-premises never ranked first. The cloud advantage over on-premises is robust to weighting; the hybrid lead over cloud is narrow and depends on the assigned hybrid scores discussed above.

Hybrid stays ahead of cloud under every one-at-a-time weight change

Hybrid minus cloud composite SPI as each weight is scaled 0× to 2× (others renormalised)

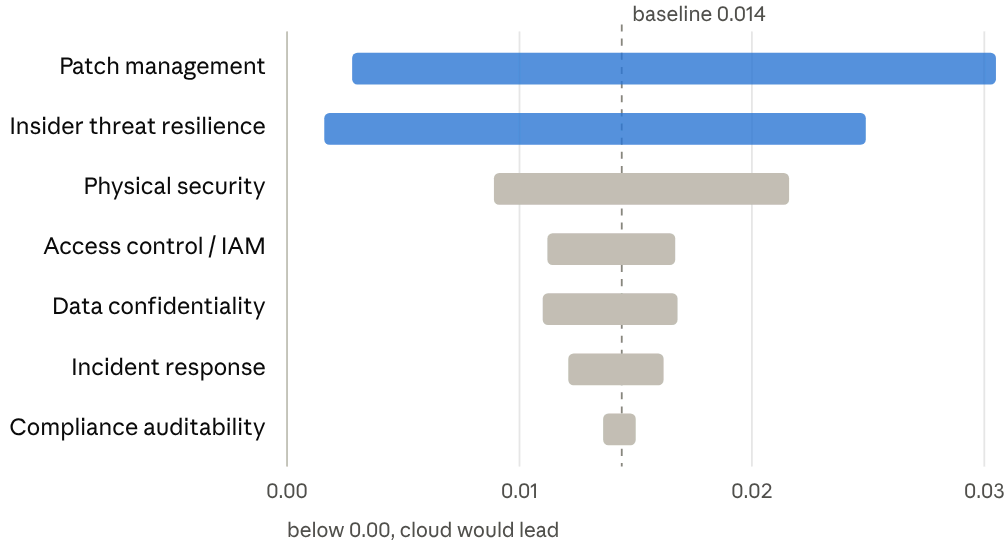


Fig. 7 — Composite SPI from Table VII, 28 one-at-a-time perturbations

The lead is most sensitive to patch-management and insider-threat weights (Fig. 7), and comes within 0.002 of zero when insider threat is dropped entirely.

Appendix B. Hybrid Security Optimization Model

HSOM turns the per-dimension comparison into a placement decision for each workload class. It is a conceptual framework for organizations to apply with their own parameters, and the breach data in Section IV cannot yet validate it. We state it as three testable propositions. P1: below some capability threshold, organizations suffer fewer breaches per workload in cloud than on-premises. P2: workloads concentrated on one shared platform suffer correlated, campaign-scale breaches, so a concentration penalty lowers expected loss. P3: identity systems that span both environments are over-represented in cross-environment attack paths. Each becomes testable once breach records identify environment and attack path, which Section IV shows they rarely do today.

Let α be the share of workload class j placed in cloud, λ its criticality weight, K its security cost in each environment, and B the security budget. Writing K for cost avoids reusing C , which denotes countermeasure effectiveness in Appendix A.

$$\min_{\alpha} \sum_{j \in \mathcal{J}} \lambda_j [\alpha_j E_j^{\text{cl}} + (1 - \alpha_j) E_j^{\text{on}}] + \gamma R(\alpha) \quad (5)$$

$$\text{s. t. } \sum_j [\alpha_j K_j^{\text{cl}} + (1 - \alpha_j) K_j^{\text{on}}] \leq B, \quad \alpha_j \in \{0, 1\} \quad \forall j \in \mathcal{J}_{\text{reg}}, \quad \alpha_j \in [0, 1] \text{ otherwise} \quad (6)$$

Without the R term the objective is linear, so the optimum places each class wholly in one environment. $R(\alpha)$ is a concentration penalty, weighted by γ , for exposure to a single provider or a single shared platform. It reflects the DORA concentration-risk requirement and the shared-platform cluster observed in Section IV. With R convex, partial placement becomes optimal where concentration cost is high. Classes subject to residency or sovereignty rules take a discrete placement.

Table X — Illustrative placement guidance

Workload class	Main driver	Suggested placement
Customer-facing web applications	Patch speed, DDoS and WAF at scale	Cloud
Development and test	Low sensitivity, disposable	Cloud
Backup and disaster recovery	Immutable storage, geographic redundancy	Cloud, with an offline copy
Analytics and ML	Elastic compute, data-lake integration	Cloud
Financial transaction processing	Residency rules, concentration risk	Hybrid: cloud compute, controlled data residency
Employee and HR records	Residency and insider visibility	In-region cloud or private cloud, chosen by κ
Identity infrastructure	Cross-environment attack paths	Hybrid, hardened at the trust boundary
Operational technology / SCADA	Physical safety, isolation	Segmented on-premises

Two cautions apply. First, data-protection law such as GDPR governs where and how data is processed; it does not require on-premises hosting. Second, the identity row matters most: Section IV shows that attacks crossing environments, such as on-premises directory compromise leading to cloud tenant takeover, are exactly what current breach coding fails to capture.